

FinWallet Fraud Akışı - Allow, Review, Deny ve Fail-Closed

Bu doküman FinWallet v1 içinde fraud kontrolünün gerçek çalışma sırasını gösterir. Mevcut implementasyonda fraud, WalletTransfer ve Purchase işlemleri öncesinde çalışır. BankDeposit happy path'i fraud servisini çağırmaz.

0. Ön koşullar

Aşağıdaki örnekte iki aktif müşteri ve iki TRY wallet vardır. Kaynak wallet daha önce BankDeposit ile fonlanmıştır.

```
{{gateway}} = http://localhost:8080
{{tokenA}} = source customer JWT
{{sourceWalletId}} = Customer A TRY wallet
{{destinationWalletId}} = Customer B TRY wallet
{{internalKey}} = Gateway InternalServiceKey
```

1. CLIENT - Fraud korumalı WalletTransfer isteği

Normal düşük riskli örnek:

```
POST {{gateway}}/api/v1/transfers
Authorization: Bearer {{tokenA}}
Idempotency-Key: fraud-allow-demo-001
Content-Type: application/json
X-Correlation-Id: fraud-allow-001

{
  "sourceWalletId": "11111111-aaaa-aaaa-aaaa-111111111111",
  "destinationWalletId": "22222222-bbbb-bbbb-bbbb-222222222222",
  "amount": 500.00
}
```

İstemci fraud sinyali göndermez. Country, device, velocity, 24 saatlik toplam, beneficiary geçmişi ve currency server-side hesaplanır.

2. Replay kontrolü fraud'dan önce çalışır

Aynı Idempotency-Key ile daha önce tamamlanmış aynı transfer varsa FinWallet stored result'ı döndürür ve fraud provider'ı tekrar çağırmaz.

```
Completed replay -> aynı transactionId -> ikinci para hareketi yok -> ikinci fraud
evaluation yok
```

Aynı key farklı amount/destination ile kullanılırsa 409 IDEMPOTENCY_CONFLICT döner.

3. Server-side risk signal okuma

FinWallet MSSQL'den şu sinyalleri çıkarır:

```
Customer/session hâlâ aktif mi?
Source wallet customer'a mı ait?
Source ve destination wallet aktif mi?
Currency nedir?
Device müşteri için yeni mi?
Son 5 dakikada kaç başarılı transfer var?
Son 24 saatte aynı currency toplamı nedir?
Destination daha önce kullanılan beneficiary mi?
CountryCode nedir?
```

Raw DeviceId dış fraud provider'a gönderilmez; hash/opaque device reference gönderilir.

4. Internal Fraud Engine

Aktif internal kurallar:

TransactionAmountFraudRule
DailyAmountFraudRule
VelocityFraudRule
NewDeviceBeneficiaryFraudRule

Karar önceliği:

Deny > Review > Allow

TRY için tek işlem tutarı kuralı örneği:

< 20,000 TRY -> amount rule Allow
=> 20,000 TRY -> amount rule Review
=> 75,000 TRY -> amount rule Deny

Internal Deny oluşursa FakeFraud hiç çağrılmaz. Çünkü external Allow internal Deny kararını override edemez.

5A. FRAUD ALLOW PATH

500 TRY ve normal velocity/device koşullarında internal karar Allow olabilir. Internal Deny yoksa FinWallet FakeFraud'a gider.

INTERNAL - FakeFraud evaluate

POST {{gateway}}/providers/fraud/api/v1/fraud/evaluate
X-Internal-Service-Key: {{internalKey}}
Content-Type: application/json
X-Correlation-Id: fraud-allow-001

Örnek PII içermeyen request:

```
{
  "transactionReference": "33333333-3333-3333-3333-333333333333",
  "customerReference": "44444444-4444-4444-4444-444444444444",
  "transactionType": "WalletTransfer",
  "amount": 500.00,
  "currency": "TRY",
  "countryCode": "TR",
  "deviceReference": "A9C8D7E6F5...",
  "isNewDevice": false,
  "transactionCountLastFiveMinutes": 0,
  "amountLastTwentyFourHours": 0.00,
  "merchantId": null
}
```

FakeFraud response:

```
{
  "isSuccess": true,
  "code": "FRAUD_EVALUATED",
  "message": "External fraud evaluation completed.",
  "data": {
    "providerReference": "55555555-5555-5555-5555-555555555555",
    "decision": 1,
    "riskScore": 0,
    "reasonCodes": ["NO_EXTERNAL_RISK_SIGNAL"]
  },
  "errors": []
}
```

decision=1 = Allow.

FinWallet combined policy:

Internal Allow + External Allow = Final Allow

Durable FraudEvent kaydı yazılır. Ardından atomic transfer posting başlar.

CLIENT success response

```
{
  "isSuccess": true,
  "code": "WALLET_TRANSFER_COMPLETED",
}
```

```
"message": "Wallet transfer completed successfully.",
"data": {
  "transactionId": "66666666-6666-6666-6666-666666666666",
  "sourceWalletId": "11111111-aaaa-aaaa-aaaa-111111111111",
  "destinationWalletId": "22222222-bbbb-bbbb-bbbb-222222222222",
  "amount": 500.00,
  "currency": "TRY",
  "completedAt": "2026-08-10T20:30:00+00:00",
  "wasReplay": false
},
"errors": []
}
```

Atomic ledger:

Debit	source Wallet Liability	500 TRY
Credit	destination Wallet Liability	500 TRY

5B. FRAUD REVIEW PATH

Örnek request: 25,000 TRY.

TRY internal single-transaction rule $\geq 20,000$ olduğu için Review üretir. FakeFraud da $\geq 25,000$ için Review üretir.

```
POST {{gateway}}/api/v1/transfers
Authorization: Bearer {{tokenA}}
Idempotency-Key: fraud-review-demo-001
Content-Type: application/json

{
  "sourceWalletId": "11111111-aaaa-aaaa-aaaa-111111111111",
  "destinationWalletId": "22222222-bbbb-bbbb-bbbb-222222222222",
  "amount": 25000.00
}
```

Combined decision:

Internal Review + External Review = Final Review

FraudEvent durable olarak Pending review state'iyle saklanır. Para hareketi ve ledger posting yapılmaz.

Public response:

```
{
  "isSuccess": false,
  "code": "TRANSFER_REVIEW_REQUIRED",
  "message": "The transfer requires additional review and no money was moved.",
  "data": null,
  "errors": []
}
```

HTTP status: 202 Accepted.

INTERNAL - Pending fraud review listesi

```
GET {{gateway}}/api/v1/internal/fraud-reviews?take=50
X-Internal-Service-Key: {{internalKey}}
```

Pending FraudEvent response içinde internal/external/final decision ve reason code'lar bulunur; request hash, token veya PII dönmez.

INTERNAL - Review approve

```
POST {{gateway}}/api/v1/internal/fraud-reviews/{{fraudEventId}}/decision
X-Internal-Service-Key: {{internalKey}}
X-Reviewer-Id: ops-reviewer-01
Content-Type: application/json

{
  "approve": true
}
```

Başarılı response code:

FRAUD_REVIEW_APPROVED

Müşteri daha sonra aynı transfer request'ini aynı Idempotency-Key ile tekrar gönderir. Handler durable FraudEvent'i bulur, external fraud'u tekrar çağırılmaz ve Approved state nedeniyle atomic posting'e devam eder.

5C. FRAUD DENY PATH

Örnek request: 100,000 TRY.

TRY internal single-transaction deny threshold 75,000 TRY olduğu için internal fraud doğrudan Deny verir. Bu durumda FakeFraud çağırılmaz.

```
POST {{gateway}}/api/v1/transfers
Authorization: Bearer {{tokenA}}
Idempotency-Key: fraud-deny-demo-001
Content-Type: application/json

{
  "sourceWalletId": "11111111-aaaa-aaaa-aaaa-111111111111",
  "destinationWalletId": "22222222-bbbb-bbbb-bbbb-222222222222",
  "amount": 100000.00
}
```

Response:

```
{
  "isSuccess": false,
  "code": "TRANSFER_FRAUD_DENIED",
  "message": "The transfer was denied by fraud controls.",
  "data": null,
  "errors": []
}
```

HTTP status: 403 Forbidden.

Durable FraudEvent tutulur; wallet balance ve ledger değişmez.

5D. FRAUD PROVIDER UNAVAILABLE - FAIL CLOSED

Internal result Deny değilse FakeFraud zorunludur. FakeFraud timeout/network/invalid response üretirse transfer finansal posting'e geçmez.

Public response:

```
{
  "isSuccess": false,
  "code": "FRAUD_DEPENDENCY_UNAVAILABLE",
  "message": "The required fraud service is temporarily unavailable.",
  "data": null,
  "errors": []
}
```

HTTP status: 503 Service Unavailable.

Fail-closed kuralı:

Fraud dependency belirsiz -> para hareketi yok -> ledger posting yok

6. Karar matrisi

Internal	External	Final davranış
Allow	Allow	Allow -> atomic posting
Review	Allow	Review -> 202, para hareketi yok
Allow	Review	Review -> 202, para hareketi yok
Review	Review	Review -> 202, para hareketi yok
Deny	Çağırılmaz	Deny -> 403
Allow/Review	Provider unavailable	503 fail-closed

7. Fraud reason code örnekleri

INTERNAL_NO_RISK_SIGNAL
INTERNAL_HIGH_TRANSACTION_AMOUNT
INTERNAL_VERY_HIGH_TRANSACTION_AMOUNT
NO_EXTERNAL_RISK_SIGNAL
HIGH_TRANSACTION_AMOUNT
VERY_HIGH_TRANSACTION_AMOUNT
ELEVATED_VELOCITY_5M
HIGH_VELOCITY_5M
ELEVATED_24H_AMOUNT
HIGH_24H_AMOUNT
NEW_DEVICE_HIGH_AMOUNT
BLOCKED_MERCHANT
HIGH_RISK_COUNTRY